

# Network Security

## Lecture 5

### Metasploit

# Today!

- Metasploit

[bristol.ac.uk](http://bristol.ac.uk)

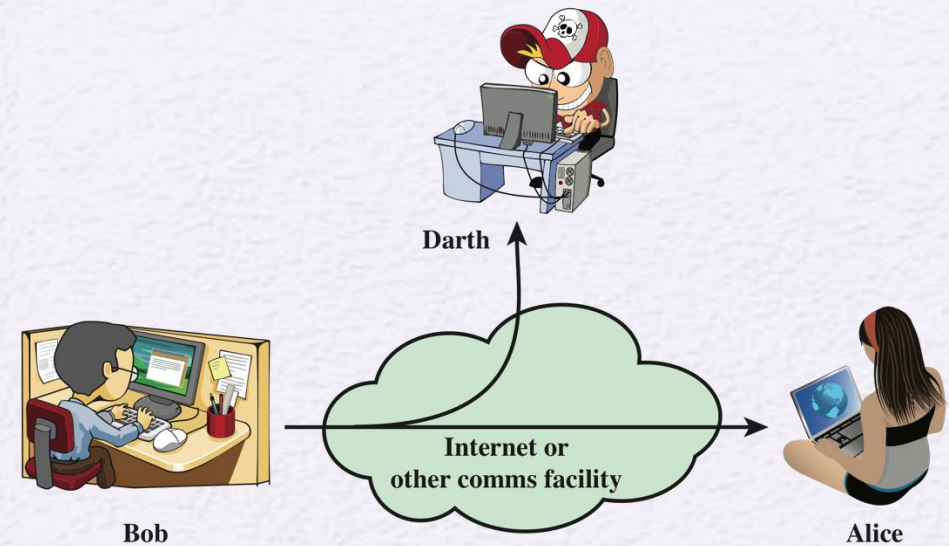




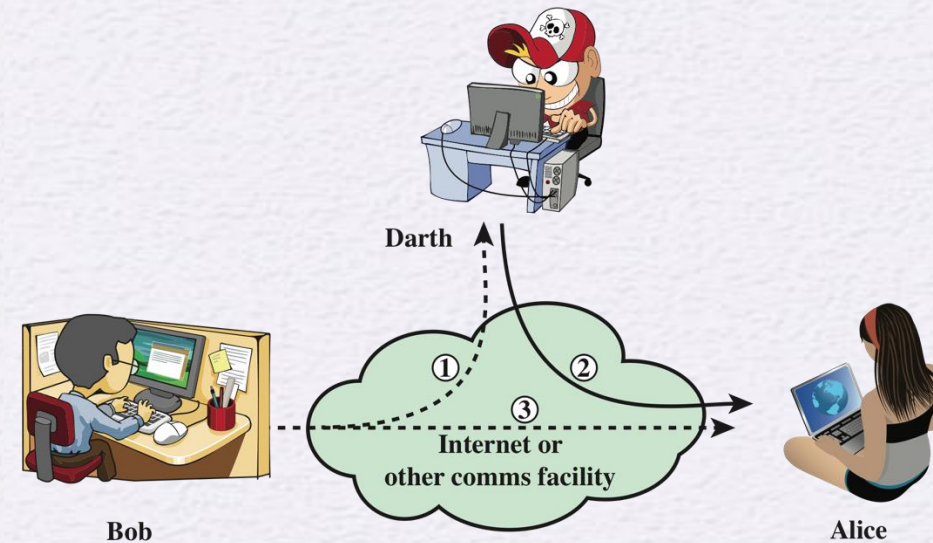
University of  
BRISTOL

# Security Attacks

- A means of classifying security attacks, used both in X.800 and RFC 4949, is in terms of *passive attacks* and *active attacks*
- A *passive attack* attempts to learn or make use of information from the system but does not affect system resources
- An *active attack* attempts to alter system resources or affect their operation



(a) Passive attacks



(b) Active attacks

# Passive Attacks

- Are in the nature of eavesdropping on, or monitoring of, transmissions
- Goal of the opponent is to obtain information that is being transmitted



- Two types of passive attacks are:
  - The release of message contents
  - Traffic analysis

# Active Attacks

- Involve some modification of the data stream or the creation of a false stream
- Difficult to prevent because of the wide variety of potential physical, software, and network vulnerabilities
- Goal is to detect attacks and to recover from any disruption or delays caused by them



## Masquerade

- Takes place when one entity pretends to be a different entity
- Usually includes one of the other forms of active attack

## Replay

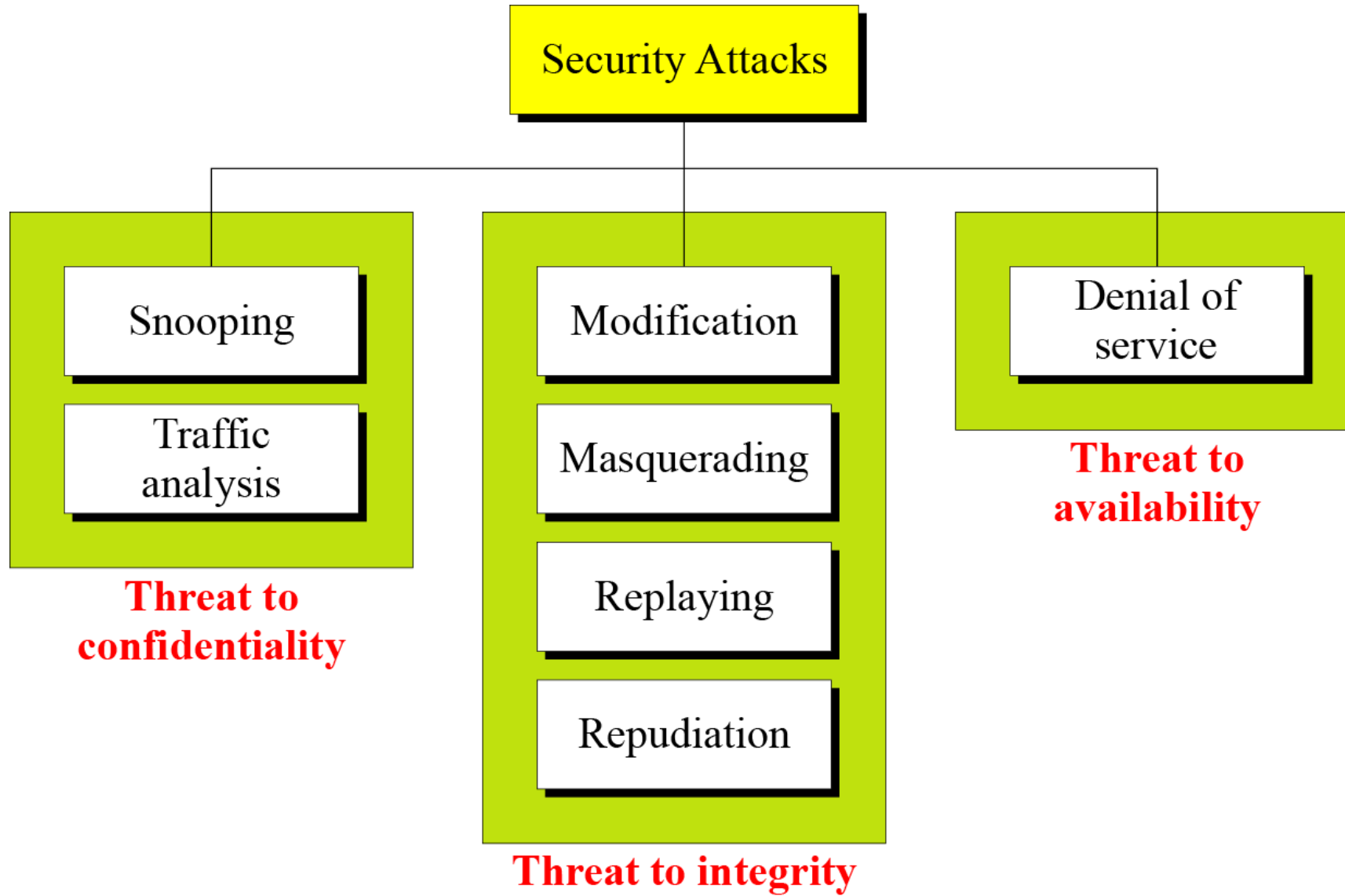
- Involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect

## Modification of messages

- Some portion of a legitimate message is altered, or messages are delayed or reordered to produce an unauthorized effect

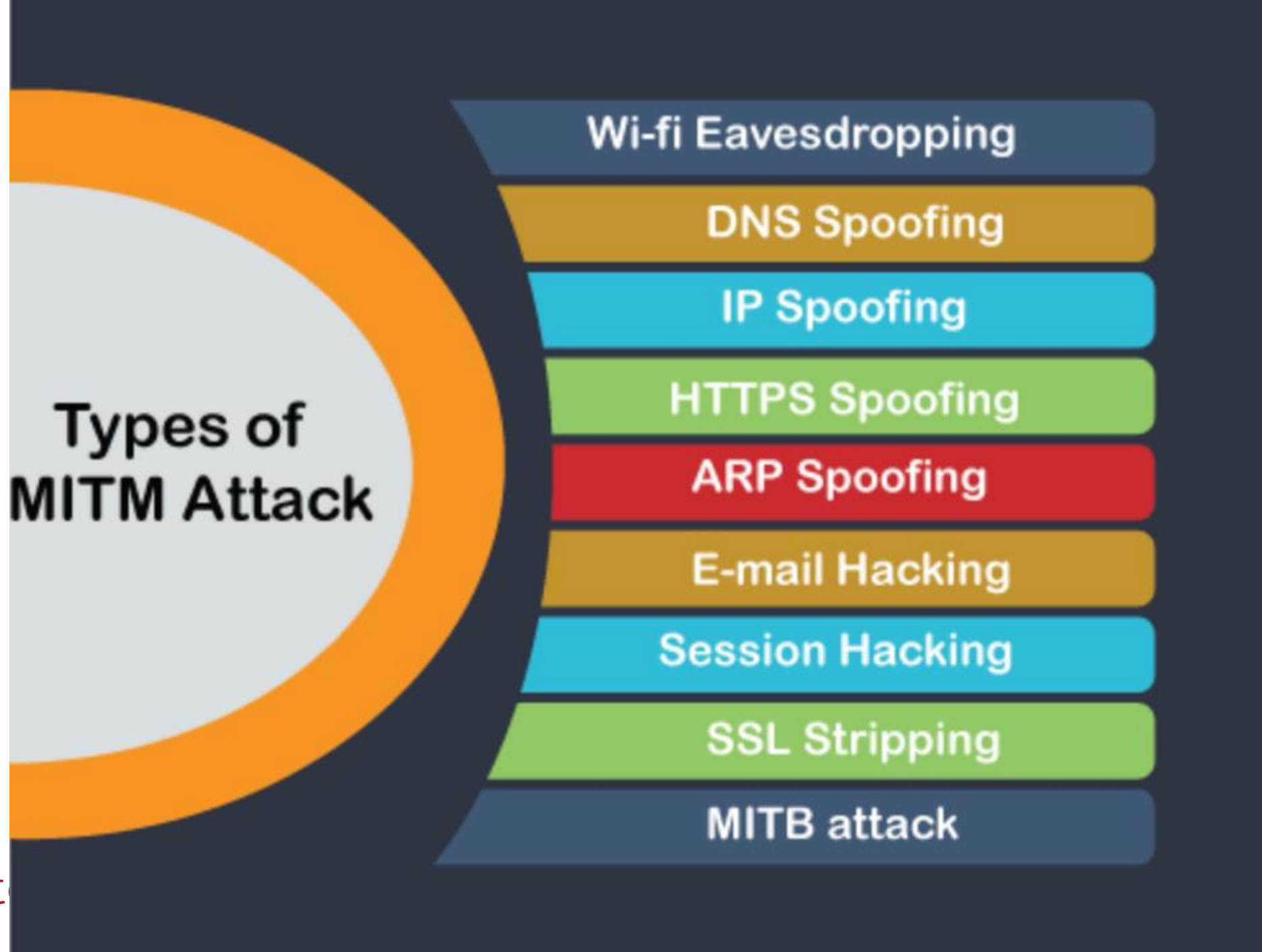
## Denial of service

- Prevents or inhibits the normal use or management of communications facilities





## Types of MITM Attack

A diagram with a dark blue background. On the left, a light gray circle is partially visible, with an orange ring around its right edge. To the right of the ring is a list of ten types of MITM attacks, each in a colored bar. The bars are arranged vertically and have a slight 3D effect with a darker blue shadow on the left side. The colors of the bars from top to bottom are: dark blue, gold, light blue, light green, red, gold, light blue, light green, light green, and dark blue.

Wi-fi Eavesdropping

DNS Spoofing

IP Spoofing

HTTPS Spoofing

ARP Spoofing

E-mail Hacking

Session Hacking

SSL Stripping

MITB attack

# Preventions of Man-in-the-middle attack

- **Wireless access point (WAP) Encryption**
- **Wireless access point (WAP) Encryption**



# Google Cloud, AWS, and Cloudflare report largest DDoS attacks ever

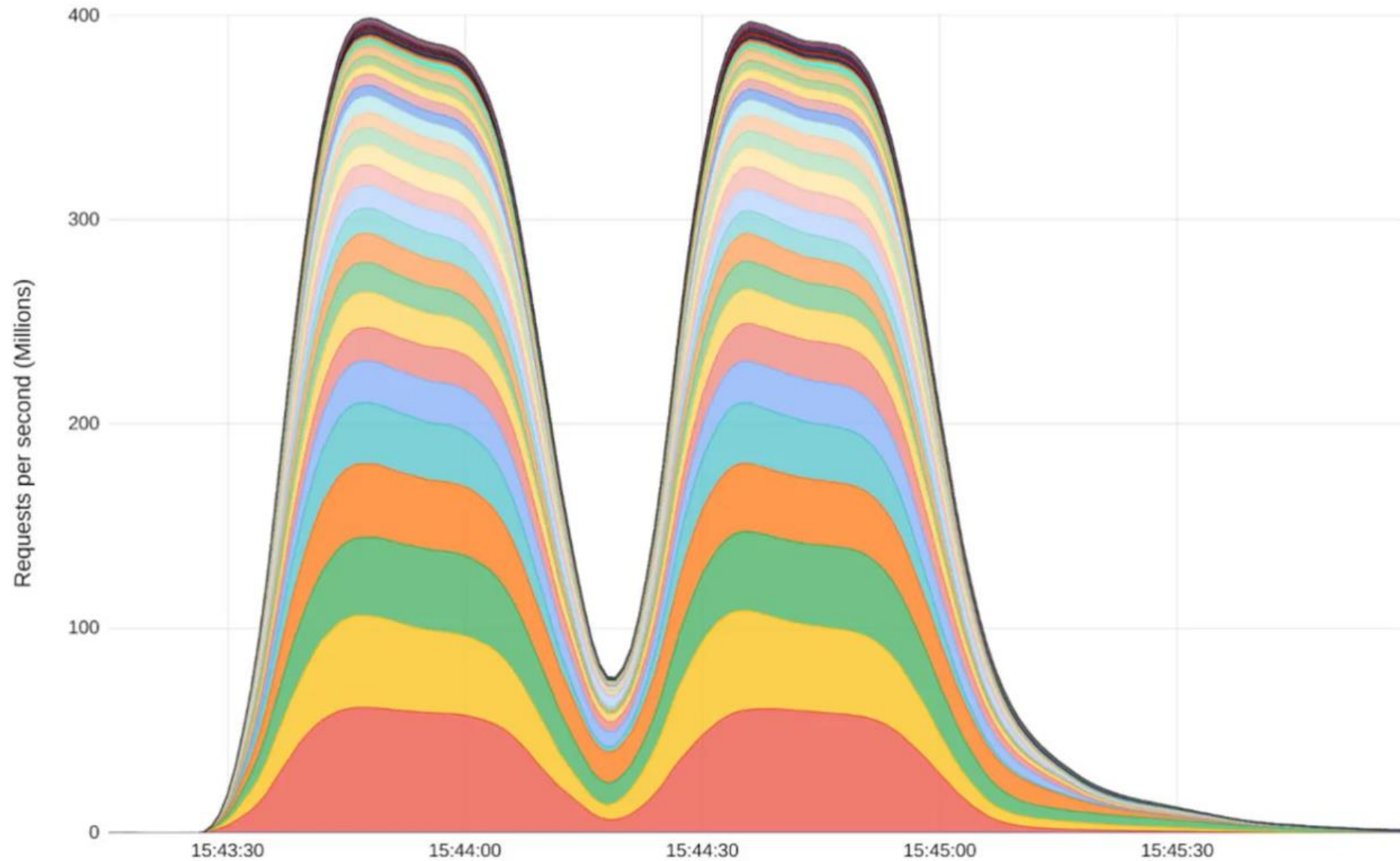
The attack on Google Cloud was 7½ times larger than any previously recorded DDoS attack. Here's what else you need to know.



Written by **Steven Vaughan-Nichols**, Senior Contributing Editor

Oct. 10, 2023 at 4:46 p.m. PT

Requests per second by Metropolitan Area



brist Monster DDoS attacks hit Google Cloud and other major internet services.

Google

Oops, your important files are encrypted.

If you see this text, then your files are no longer accessible, because they have been encrypted. Perhaps you are busy looking for a way to recover your files, but don't waste your time. Nobody can recover your files without our decryption service.

We guarantee that you can recover all your files safely and easily. All you need to do is submit the payment and purchase the decryption key.

Please follow the instructions:

1. Send \$300 worth of Bitcoin to following address:

1Mz7153HMuxXTuR2R1t78mGSdzaAtNbBX

2. Send your Bitcoin wallet ID and personal installation key to e-mail wowsmith123456@posteo.net. Your personal installation key:

If you already purchased your key, please enter it below.  
Key:

# What is wiper? (1/2)

- A wiper is a type of malware with a single purpose: to erase user data beyond recoverability.
- Wipers are used to destroy computer networks in public or private companies ranging from industrial to entertainment sectors.
- Threat actors also use wipers to cover up traces left after an intrusion, weakening their victim's ability to respond.

```
// e2ecec43da974db02f624ecadc94baf1d21fd1a5c4990c15863bb9929f781a0a
IterateFilesAndWipe(wchar_t *Format)
{
    // ...
    FirstFileW = FindFirstFileW(FileName, &FindFileData);
    // ...
    do
    {
        // ...
        if ( (FindFileData.dwFileAttributes & FILE_ATTRIBUTE_DIRECTORY) != 0 )
        {
            // ...
            IterateFilesAndWipe(strfileName);
        }
        else
        {
            // ...
            WipeFile(strfileName);
        }
    }
    while ( FindNextFileW(FirstFileW, &FindFileData) );
}
```

Figure 1. File iteration via FindFirstFile and FindNextFile APIs

# What is wiper? (2/2)

- Wipers are implemented to do as much damage as possible without crashing the operating system.
- During the file discovery operation, many wipers will implement different strategies to maintain the stability of the operating system.

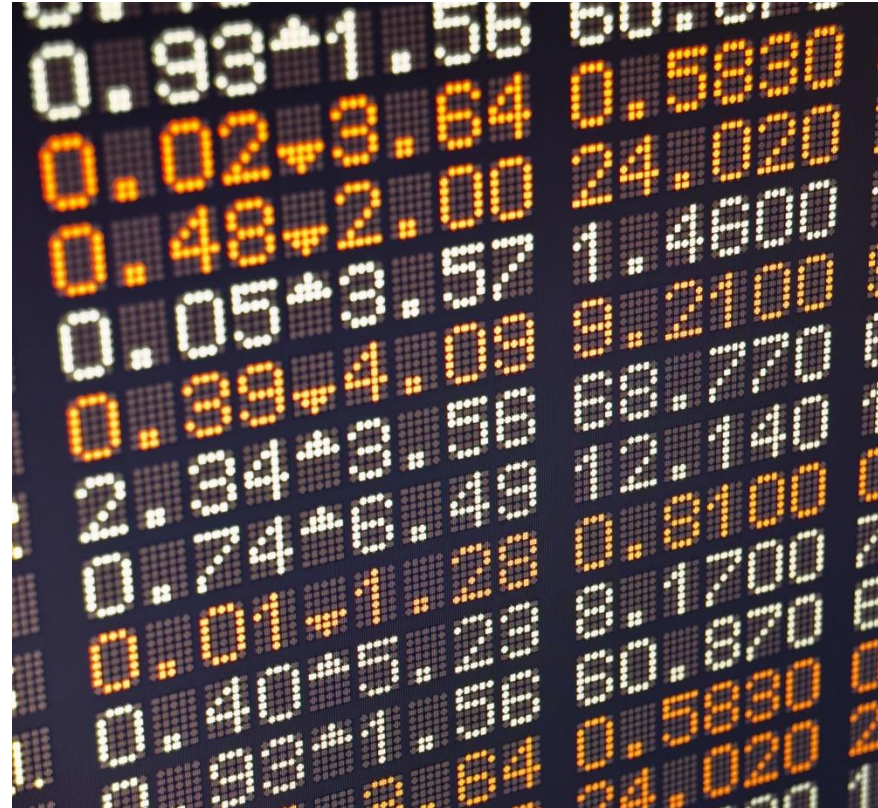
```
// e2ecec43da974db02f624ecadc94baf1d21fd1a5c4990c15863bb9929f781a0a
int WipeFile(LPCWSTR lpFileName)
{
    SetFileAttributesW(lpFileName, FILE_ATTRIBUTE_NORMAL);
    hFile = CreateFileW(
        lpFileName,
        GENERIC_WRITE|GENERIC_READ,
        FILE_ATTRIBUTE_HIDDEN|FILE_ATTRIBUTE_READONLY, 0,
        CREATE_NEW | CREATE_ALWAYS, 0, 0);
    // ...
    FileSize = GetFileSize(hFile, 0);
    hBuff = malloc(FileSize);
    if ( hBuff )
    {
        ExtensionW = PathFindExtensionW(lpFileName);
        if ( SkipTheseExtensions(ExtensionW) )
            WriteFile(hFile, hBuff, FileSize, &lpFileName, 0);
        CloseHandle(hFile);
        free(hBuff);
        return 1;
    }
    return hBuff;
}
```

Figure 2. Determine file size, allocate memory and write to file



## One of the most devastating Cyberattack in history

- On 27 June 2017, a major global cyber-attack struck banks, airports and energy companies in Ukraine
- The most impacted country, was likely the intended target.
- Europe was also impacted





# Wiper malware attack

- 23 February 2022 - data wiper malware was detected on hundreds of computers belonging to multiple Ukrainian organizations, including in the financial, defense, aviation, and IT services sectors.
- The EU had deployed a cyber rapid-response team consisting of about ten cybersecurity experts from Lithuania, Croatia, Poland, Estonia, Romania, and the Netherlands.





University of  
BRISTOL

How can someone with  
malicious intent mess with my  
network?

[bristol.ac.uk](http://bristol.ac.uk)

# Pen-testing

- Using pen-testing tools, white hats and DevSec professionals are able to probe networks and applications for flaws and vulnerabilities at any point along the production and deployment process by hacking the system.



# METASPLOIT



[bristol.ac.uk](http://bristol.ac.uk)



# Metasploit?

- The Metasploit Project is a computer security project that provides information about security vulnerabilities and aids in penetration testing and IDS signature development.
- It is owned by Boston, Massachusetts-based security company Rapid7.
- The Metasploit Project includes anti-forensic and evasion tools, some of which are built into the Metasploit Framework.



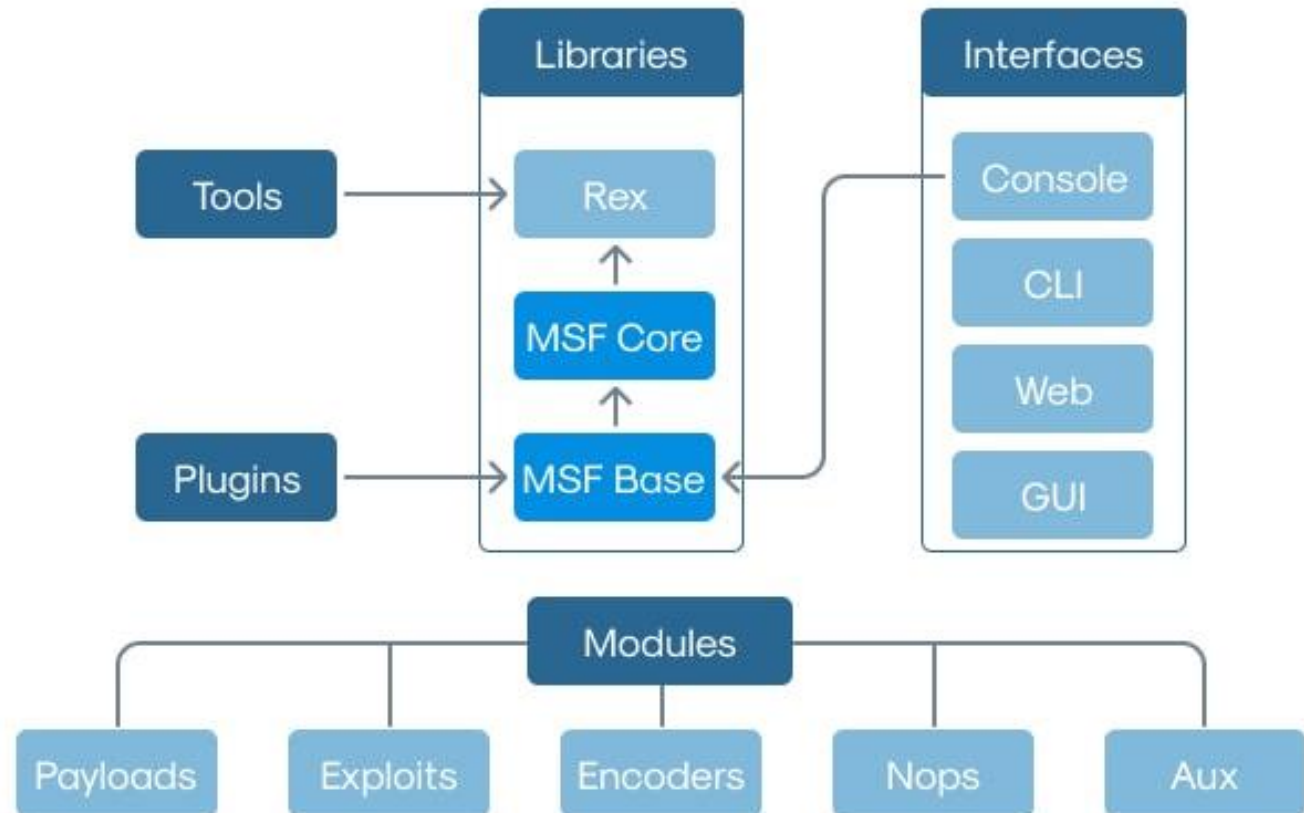


# Metasploit Framework



- Auxiliary
- Exploits
- Payloads
- Encoders

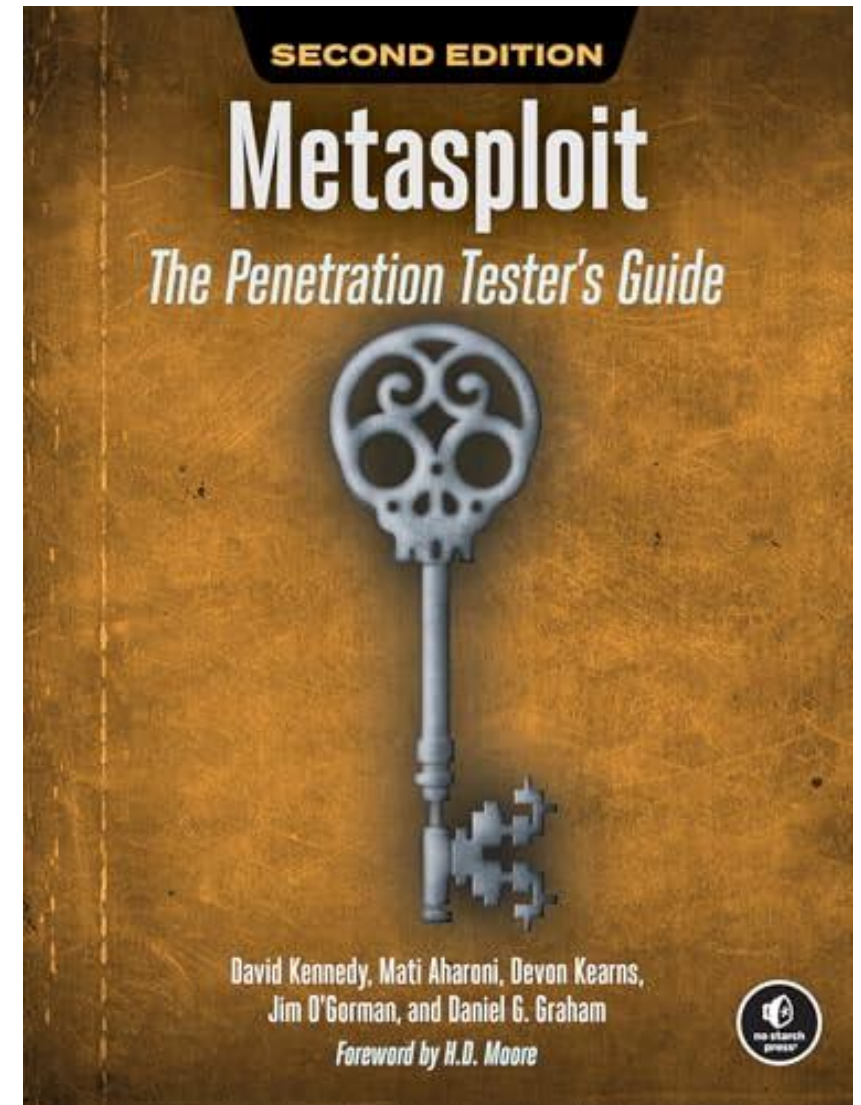
## Metasploit Architecture



# Metasploit Framework

[illegible]

bristol.ac.uk



# More hacking beyond Metasploit



- With training



- More difficult

# Even more hacking

- OverTheWire
- Root Me
- PortSwigger Web Security Academy
- CTFlearn
- PicoCTF
- CTFTIME

bristol.ac.uk

- <https://www.hackthissite.org/>

The screenshot shows the HackThisSite.org website. At the top, there's a navigation bar with links: Hack This Site (TOR, onion, HTTPS - HTTP) - IRC - Discord - Forums - Store - URL Shortener - CryptoPaste - Like Us - Follow Us - Fork Us. Below this is a large banner with the site's logo and a message: "Support HackThisSite UNLIMITED ... Impressions". A smaller text below the banner says "How sad to love money".

On the left side, there's a user profile section for "Marinerjack" with links for Settings and Logout. Below this is a "Skin Chooser" and a "Private Messages" section showing "HTS Messages Center" and "You have 0 new messages." There's also a "Donate" button and a "DONATE" button with a dollar sign icon. Below the donate button, it says "basic attention token" and "HTS costs up to \$300 a month to operate. We need your help!".

In the center, there's a section titled "Challenges" with a list of challenge types: Basic, Realistic, Application, Programming, Javascript, Forensic, and Extended Basic. To the right of this is a section titled "Training the hacker underground" with a drawing of a computer monitor and keyboard.

On the right side, there's a "STAFF BLOGS / SHORT NEWS:" section with links to "blog Status Pages 2.0 - N...", "news Application 2", "news Application 7 & ...", "blog Github for Status Pa...", and "blog Internetwache CTF 20...". Below this is a "LATEST ARTICLES:" section with links to "How are websites defaced?", "What is OSINT and what are t...", "How to stay anonymous &a...", and "Realistic mission 1 tutorial Cryptanalysis".

At the bottom right, there's a "HackThisSite on GitHub:" section with a table showing statistics:

| HackThisSite on GitHub: |     |
|-------------------------|-----|
| Repositories            | 21  |
| Forks                   | 108 |
| Watchers                | 360 |
| Stargazers              | 360 |
| Contributors            | 7   |
| Commits This Week       | 0   |

At the very bottom, there's a "CONTRIBUTE:" section with a link to "100+ Discord (1405) - 100+ ...".

# Your target

<https://docs.rapid7.com/metasploit/metasploitable-2/>

**RAPID7 Docs**

Documentation HomeProductsRelease NotesSupport ↗Sign In

Welcome ▾

Installing Metasploit ▴

Installing Metasploit Pro ▾

Setting Up a Vulnerable Target ▴

Metasploitable 2

Metasploitable 2 Exploitability Guide

Discovery ▾

Validate Vulnerabilities ▾

Exploitation ▾

Payloads ▾

Post-exploitation ▾

## Metasploitable 2 # 🔗

A test environment provides a secure place to perform penetration testing and security research. For your test environment, you need a Metasploit instance that can access a vulnerable target. The following sections describe the requirements and instructions for setting up a vulnerable target. **Downloading and Setting Up Metasploitable 2** The easiest way to get a target machine is to use Metasploitable 2, which is an intentionally vulnerable Ubuntu Linux virtual machine that is designed for testing common vulnerabilities. This virtual machine (VM) is compatible with VMWare, VirtualBox, and other common virtualization platforms.

Metasploitable 2 is available at:

- <https://information.rapid7.com/metasploitable-download.html> ↗
- <https://sourceforge.net/projects/metasploitable/> ↗

The compressed file is about 800 MB and can take a while to download over a slow connection. After you have downloaded the Metasploitable 2 file, you will need to unzip the file to see its contents.



# Lock and Load



[bristol.ac.uk](http://bristol.ac.uk)

